

Fundamentals of Information Systems Security

The Cyber Kill Chain

Understanding the Adversary Lifecycle

Lockheed Martin's

Intelligence-Driven Defense Model

The Cyber Kill Chain is a framework for understanding and defending against cyber attacks. It describes the stages of a cyber attack, from initial reconnaissance to achieving the attacker's objectives. By understanding each stage, defenders can implement targeted controls to stop attacks at every phase.

Ransomware;

Version: 2.0

Format: Quick Reference Guide

Date: June 16, 2026

Contents

1	Overview	3
1.1	What is the Cyber Kill Chain?	3
1.2	The Seven Stages	3
2	Detailed Stage Analysis	4
2.1	Stage 1: Reconnaissance	4
2.1.1	Reconnaissance Activities	4
2.1.2	Detection and Defense	4
2.2	Stage 2: Weaponization	5
2.2.1	Weaponization Activities	5
2.2.2	Detection and Defense	5
2.3	Stage 3: Delivery	6
2.3.1	Delivery Methods	6
2.3.2	Detection and Defense	6
2.4	Stage 4: Exploitation	7
2.4.1	Common Exploits	7
2.4.2	Detection and Defense	7
2.5	Stage 5: Installation	8
2.5.1	Persistence Mechanisms	8
2.5.2	Detection and Defense	8
2.6	Stage 6: Command and Control (C2)	9
2.6.1	C2 Methods	9
2.6.2	Detection and Defense	9
2.7	Stage 7: Actions on Objectives	10
2.7.1	Common Objectives	10
2.7.2	Detection and Defense	10
3	MITRE ATT&CK vs. Cyber Kill Chain	11
3.1	Comparison Table	11
3.2	Mapping Cyber Kill Chain to MITRE ATT&CK	11
4	Defense-in-Depth Across the Kill Chain	12
4.1	Comprehensive Defense Matrix	12
4.2	Layered Defense Strategy	12
5	Real-World Examples	13
5.1	Notable Attacks Mapped to the Kill Chain	13
5.2	Practical Applications	13
6	Key Takeaways	14
7	References	15
8	Glossary	16

1 Overview

1.1 What is the Cyber Kill Chain?

Definition

The **Cyber Kill Chain** is a model developed by **Lockheed Martin** that describes the stages of a cyber attack from initial reconnaissance to achieving the attacker's objectives. It provides a framework for understanding the adversary's methodology and identifying opportunities for defense at each stage.

1.2 The Seven Stages

The Attack Lifecycle

Stage	Name	Action	Risk Level
1	Reconnaissance	Information Gathering	
2	Weaponization	Malware Development	
3	Delivery	Payload Transmission	
4	Exploitation	Vulnerability Exploitation	
5	Installation	Persistence Establishment	
6	Command & Control (C2)	Remote Access & Control	
7	Actions on Objectives	Mission Accomplishment	

2 Detailed Stage Analysis

2.1 Stage 1: Reconnaissance

Reconnaissance

The attacker gathers information about the target. This is the planning phase where attackers research potential victims, identify vulnerabilities, and develop attack strategies.

2.1.1 Reconnaissance Activities

Activity	Description	Tools/Techniques
Open Source Intelligence (OSINT)	Public information gathering	Google, LinkedIn, Shodan, Twitter
Network Scanning	Discovering network topology	Nmap, Masscan, ZMap
Social Engineering	Gathering information from people	Phishing, Pretexting, Baiting
Vulnerability Research	Identifying weaknesses	CVE databases, Exploit-DB, CISA
DNS Enumeration	Discovering domain infrastructure	DNSRecon, dnsdumpster, Dig

2.1.2 Detection and Defense

Defense Strategies

- Minimize publicly available sensitive information
- Monitor for reconnaissance activities (IDS/IPS)
- Implement strong access controls
- Conduct regular penetration testing
- Train employees on OSINT risks
- Use threat intelligence to identify probing activities
- Implement deception technologies (honeypots)
- Monitor DNS queries and network scans

2.2 Stage 2: Weaponization

Weaponization

The attacker creates a malicious payload designed to exploit identified vulnerabilities. This is where malware is developed or customized.

2.2.1 Weaponization Activities

Activity	Description	Tools/Techniques
Malware Creation	Developing malicious code	Python, C++, Assembly, Rust
Exploit Development	Creating code to exploit vulnerabilities	Metasploit, Immunity Debugger, IDA Pro
Payload Generation	Creating malicious payloads	msfvenom, Empire, Cobalt Strike
Packaging	Bundling malware with legitimate software	Self-extracting archives, PDFs, Office docs
Encryption/Obfuscation	Avoiding detection	XOR, Base64, Packers, Crypters

2.2.2 Detection and Defense

Defense Strategies

- Application whitelisting
- Code signing verification
- Antivirus/EDR with behavioral analysis
- Email filtering and attachment scanning
- Sandboxing for suspicious files
- Regular software updates
- Memory protection (ASLR, DEP)
- Control Flow Guard (CFG)

2.3 Stage 3: Delivery

Delivery

The weaponized payload is transmitted to the target. This is the point where the attacker attempts to deliver the malicious package to the victim.

2.3.1 Delivery Methods

Method	Description	Examples
Phishing Emails	Malicious attachments or links	Spear phishing, mass phishing
Drive-By Downloads	Malware from compromised web-sites	Malvertising, watering holes
USB Devices	Physical media delivery	USB drop attacks, BadUSB
Supply Chain	Compromised software updates	SolarWinds, CCleaner
Social Engineering	Tricking users into downloading	Impersonation, baiting

2.3.2 Detection and Defense

Defense Strategies

- Email filtering and spam protection
- Web filtering and URL blocking
- Endpoint Detection and Response (EDR)
- Security awareness training
- Blocking unknown USB devices
- Vendor security assessments
- Implement DMARC, SPF, DKIM
- Browser sandboxing and isolation

2.4 Stage 4: Exploitation

Exploitation

The malicious payload is executed on the target system. This stage involves triggering the vulnerability to gain access.

2.4.1 Common Exploits

Type	Description	Examples
Zero-Day	Previously unknown vulnerability	CVE-2021-44228 (Log4Shell)
Buffer Overflow	Writing beyond memory boundaries	EternalBlue (SMB)
SQL Injection	Manipulating database queries	CVE-2019-11510 (Pulse VPN)
Cross-Site Scripting	Injecting client-side scripts	OWASP Top 10
Credential Theft	Stealing passwords	Keyloggers, Mimikatz

2.4.2 Detection and Defense

Defense Strategies

- Regular patching and vulnerability management
- Application whitelisting
- User account least privilege
- Application controls (AppLocker, SELinux)
- Input validation (SQL injection prevention)
- Memory protection (ASLR, DEP)
- Web Application Firewalls (WAF)
- Runtime application self-protection (RASP)

2.5 Stage 5: Installation

Installation

The attacker establishes persistence on the compromised system. This ensures continued access even after reboots.

2.5.1 Persistence Mechanisms

Method	Description	Examples
Registry Modifications	Windows persistence	Run keys, Services
Scheduled Tasks	Automated execution	cron, Task Scheduler
Startup Folders	Auto-start applications	Startup folder, init.d
Backdoors	Hidden access methods	Web shells, SSH keys
Rootkits	Operating system modification	User-mode, Kernel-mode

2.5.2 Detection and Defense

Defense Strategies

- File integrity monitoring
- Registry monitoring
- EDR with persistence detection
- Application control and whitelisting
- Regular security audits
- Host-based intrusion detection
- Monitor for unexpected scheduled tasks
- Use Sysinternals Autoruns

2.6 Stage 6: Command and Control (C2)

Command and Control

The attacker establishes communication with the compromised system. This allows remote control and data exfiltration.

2.6.1 C2 Methods

Method	Description	Examples
HTTP/HTTPS	Web-based communication	Botnets, RATs
DNS Tunneling	DNS queries for C2	DNSScat, Iodine
IRC/IM	Chat protocols	IRC bots
Email	Email-based commands	Stolen credentials
Custom Protocols	Proprietary communication	Advanced malware

2.6.2 Detection and Defense

Defense Strategies

- Network monitoring and analysis
- DNS filtering and monitoring
- Proxy and firewall logging
- TLS/SSL decryption (with approval)
- Threat intelligence for known C2 domains
- Behavioral anomaly detection
- Implement DNS Security Extensions (DNSSEC)
- Use threat intelligence feeds

2.7 Stage 7: Actions on Objectives

Actions on Objectives

The attacker achieves their ultimate goal. This is the final stage of the attack where the objective is accomplished.

2.7.1 Common Objectives

Objective	Description	Examples
Data Theft	Exfiltrating sensitive data	Financial data, PII, IP
Ransomware	Encrypting files for ransom	DarkSide, WannaCry, LockBit
Espionage	Intelligence gathering	SolarWinds, APT29, APT28
Sabotage	Destroying or altering data	Stuxnet, Ukraine power grid
Lateral Movement	Moving to other systems	Pivoting, PSEXEC, RDP
Financial Fraud	Stealing money	Banking trojans, ransomware

2.7.2 Detection and Defense

Defense Strategies

- Data Loss Prevention (DLP)
- Network segmentation
- Least privilege access
- Data encryption at rest and in transit
- Incident response capability
- Business continuity planning
- Regular backups (offline)
- User and entity behavior analytics (UEBA)

3 MITRE ATT&CK vs. Cyber Kill Chain

3.1 Comparison Table

Cyber Kill Chain vs. MITRE ATT&CK		
Feature	Cyber Kill Chain	MITRE ATT&CK
Focus	End-to-end attack lifecycle	Specific adversary techniques
Structure	7 sequential stages	14 tactics, hundreds of techniques
Perspective	Attacker-centric	Defender-centric
Granularity	High-level summary	Very detailed
Use Case	Strategic defense	Operational defense
Coverage	Broad overview	Comprehensive catalog

3.2 Mapping Cyber Kill Chain to MITRE ATT&CK

Mapping Guide		
Kill Chain Stage	ATT&CK Tactic	Key Techniques
Reconnaissance	Reconnaissance (TA0043)	T1590, T1591, T1592, T1593, T1595
Weaponization	Resource Development (TA0042)	T1587, T1588, T1585, T1586
Delivery	Initial Access (TA0001)	T1566, T1190, T1189, T1078
Exploitation	Execution (TA0002)	T1059, T1203, T1210, T1047
Installation	Persistence (TA0003), Privilege Escalation (TA0004)	T1547, T1053, T1505, T1543
C&C	Command and Control (TA0011)	T1071, T1090, T1572, T1043
Actions	Collection (TA0009), Exfiltration (TA0010), Impact (TA0040)	T1048, T1567, T1020, T1485, T1486

4 Defense-in-Depth Across the Kill Chain

4.1 Comprehensive Defense Matrix

Defense at Each Stage			
Stage	Offensive Action	Defensive Countermeasure	Detection Method
Reconnaissance	Information gathering	OSINT minimization, Monitoring	IDS/IPS alerts, log analysis
Weaponization	Malware development	Anti-malware, EDR	Sandboxing, behavioral analysis
Delivery	Transmission to target	Email filtering, Web proxies	Email gateway, URL filtering
Exploitation	Vulnerability exploitation	Patching, Application control	Exploit detection, HIDS
Installation	Persistence establishment	Integrity monitoring, EDR	File system monitoring
C&C	Remote control	Network monitoring, DNS filtering	Anomaly detection, SIEM
Actions	Objective completion	Segmentation, DLP, IR	UEBA, DLP alerts

4.2 Layered Defense Strategy

The Defense-in-Depth Approach	
1. Physical Security:	Locks, guards, surveillance, environmental controls
2. Network Security:	Firewalls, IDS/IPS, VPN, segmentation, monitoring
3. Host Security:	Antivirus, EDR, application whitelisting, patching
4. Application Security:	Secure coding, WAF, input validation, RASP
5. Data Security:	Encryption, DLP, access controls, backup
6. User Security:	Awareness training, MFA, least privilege, background checks
7. Incident Response:	Preparation, detection, containment, recovery

5 Real-World Examples

5.1 Notable Attacks Mapped to the Kill Chain

Attack Case Studies

Attack	Year	Kill Chain Application
SolarWinds	2020	Delivery via software updates, espionage objectives
Colonial Pipeline	2021	Initial access via compromised VPN, ransomware objectives
WannaCry	2017	Exploitation of EternalBlue, ransomware objectives
Stuxnet	2010	Delivery via USB, sabotage objectives
Target Breach	2013	Initial access via HVAC vendor, data theft objectives
Log4j (Log4Shell)	2021	Exploitation of Java library, various objectives

5.2 Practical Applications

How Security Teams Use the Kill Chain

- **Threat Intelligence:** Map adversary behavior to kill chain stages
- **Incident Response:** Identify current stage for containment decisions
- **Security Architecture:** Design controls for each stage
- **Tabletop Exercises:** Simulate attacks by walking through each stage
- **Red Teaming:** Emulate adversary TTPs across all stages
- **Blue Teaming:** Detect and respond at each stage
- **Cyber Threat Hunting:** Proactively search for indicators at each stage

6 Key Takeaways

Summary of Key Concepts

1. **Defense in Depth:** Implement controls at every stage of the kill chain
2. **Early Detection:** The earlier you detect an attack, the easier it is to stop
3. **Layered Controls:** No single control is sufficient, use multiple layers
4. **Understanding Adversaries:** Know how attackers think and operate
5. **Continuous Improvement:** Learn from incidents and update defenses
6. **Human Factor:** Security awareness training is critical
7. **Threat Intelligence:** Stay informed about emerging threats
8. **Incident Response:** Have plans and practice them regularly
9. **Collaboration:** Work with other organizations and share information
10. **Resilience:** Build systems that can withstand and recover from attacks

7 References

Further Reading

- Lockheed Martin. (2015). *The Cyber Kill Chain: An Intelligence-Driven Defense Model*.
- Hutchins, E.M., Cloppert, M.J., & Amin, R.M. (2011). *Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns*.
- MITRE Corporation. (2023). *MITRE ATT&CK Framework*.
- NIST Special Publication 800-61. *Computer Security Incident Handling Guide*.
- OWASP. (2021). *OWASP Top 10 Web Application Security Risks*.
- CISA. (2023). *StopRansomware Guide*.
- Verizon. (2023). *Data Breach Investigations Report (DBIR)*.

8 Glossary

Key Terms

Term	Definition
C2 (Command and Control)	Communication channel between attacker and compromised system
EDR	Endpoint Detection and Response - Security solution for endpoint monitoring
HIDS	Host-based Intrusion Detection System
IPS	Intrusion Prevention System - Network security device that blocks threats
MITRE ATT&CK	Framework of adversary tactics, techniques, and procedures
OSINT	Open Source Intelligence - Information gathered from public sources
Persistence	Ability of malware to maintain access across reboots
Ransomware	Malware that encrypts files and demands payment
RAT	Remote Access Trojan - Malware that provides remote control
SIEM	Security Information and Event Management - Log aggregation and analysis
TTP	Tactics, Techniques, and Procedures - How attackers operate
UEBA	User and Entity Behavior Analytics - Anomaly detection
Zero-Day	Vulnerability unknown to the software vendor